

IMPORTACIÓN DE INVENTARIO

Manual: carga de software con Syft

Cómo instalar Syft, generar el inventario de software de un activo y subirlo a GEF Secure para escanear vulnerabilidades sin errores de nombre.

1. Qué es esto y para qué sirve

GEF Secure necesita saber qué software corre en cada activo (servidor, PC, contenedor) para poder cruzarlo contra fuentes de vulnerabilidades. Cargar ese software a mano tiene un problema: si el nombre que escribís no coincide exactamente con el nombre «oficial» del paquete (ej. `spring-boot-starter-web` en vez de `org.springframework.boot:spring-boot-starter-web`), el escaneo nunca va a encontrar nada — y en algunos casos directamente queda colgado.

Syft es una herramienta gratuita y de código abierto que lee el software realmente instalado/desplegado en un activo y genera un **SBOM** (*Software Bill of Materials*, un inventario estándar) con los nombres exactos de cada paquete. GEF Secure puede importar ese archivo directamente, así el software queda cargado sin errores de tipeo ni de formato.

El flujo completo tiene tres pasos:

1. Instalar Syft en la máquina que querés inventariar (una sola vez).
2. Correr Syft apuntando a la app/artefacto desplegado, generar el archivo JSON.
3. Subir ese archivo en GEF Secure, revisar la vista previa y confirmar.

2. Instalar Syft (Windows)

No requiere instalación real — es un único ejecutable portable, sin dependencias.

1 Descargar y descomprimir

```
# 1. Descargar el ZIP de la última versión
# (fijate la versión más reciente en https://github.com/anchore/syft/releases)
Invoke-WebRequest -Uri "https://github.com/anchore/syft/releases/download/v1.51.0/syft

# 2. Descomprimir en una carpeta fija
Expand-Archive -Path "$env:TEMP\syft.zip" -DestinationPath "C:\Tools\syft" -Force

# 3. (Opcional pero recomendado) agregarlo al PATH del usuario
[Environment]::SetEnvironmentVariable(
    "Path",
    "$([Environment]::GetEnvironmentVariable('Path','User'));C:\Tools\syft",
    "User"
)
# Cerrá y volvé a abrir la terminal para que tome el PATH nuevo

# 4. Verificar que funciona
syft version
```

Si todo salió bien, `syft version` muestra algo como:

```
Application:  syft
Version:      1.51.0
```

Platform: windows/amd64

No necesitas permisos de administrador ni reiniciar la máquina.

3. Usar Syft para generar el inventario

Syft detecta automáticamente qué tipo de app hay en la ruta que le pases, y arma el JSON en formato **CycloneDX** (el que entiende GEF Secure) con el flag `-o cyclonedx-json`.

3.1. Apps con manifiesto de dependencias (Maven, npm, pip, RubyGems, Composer, etc.)

Apuntá a la **carpeta** donde está la app (o el `.jar` / `.war` ya compilado, si es Java):

```
# Backend Java/Maven
syft dir:C:\apps\mi-backend -o cyclonedx-json > backend.json

# Frontend Node/npm
syft dir:C:\apps\mi-frontend -o cyclonedx-json > frontend.json
```

Syft busca `pom.xml` / `.jar` (Maven), `package.json` (npm), `requirements.txt` /venv (pip), `Gemfile.lock` (RubyGems), `composer.json` (Composer), etc. dentro de esa carpeta, y resuelve automáticamente el árbol completo de dependencias — no hace falta indicarle el ecosistema.

Importante: si es una app Java compilada (jar/war), apuntá a la carpeta donde está el artefacto ya buildeado (o directo al archivo `.jar`), no al código fuente sin compilar — así Syft puede leer las dependencias transitivas reales, con sus versiones exactas resueltas.

3.2. Binarios compilados (Go)

Apuntá directo al ejecutable:

```
syft C:\apps\mi-servicio-go.exe -o cyclonedx-json > go-app.json
```

Syft lee el *build info* que Go embebe en el binario desde la versión 1.18 — no hace falta tener el código fuente ni el toolchain de Go instalado en esa máquina para leerlo, alcanza con el ejecutable.

3.3. Imágenes Docker

```
syft mi-imagen:tag -o cyclonedx-json > docker.json
```

Funciona tanto con una imagen ya descargada localmente como con una en un registry accesible.

3.4. Varias apps en el mismo activo

Un servidor puede correr varias apps a la vez. Corr  Syft una vez por cada una y generar  un JSON por app — todos se pueden subir por separado al mismo activo en GEF Secure, cada uno suma software, ninguno pisa al anterior.

```
syft dir:C:\apps\backend -o cyclonedx-json > backend.json
syft dir:C:\apps\frontend -o cyclonedx-json > frontend.json
syft C:\apps\worker.exe -o cyclonedx-json > worker.json
```

4. Subir el inventario a GEF Secure

1. Entr  a **Activos** en el men  lateral.
2. Hac  clic en el activo al que corresponde el software (el servidor/PC que acab s de inventariar con Syft).
3. En el modal que se abre, hac  clic en **«Importar inventario»** (al lado de «Agregar Software»).
4. Eleg  el archivo `.json` que gener  Syft.
5. Hac  clic en **«Vista previa»**. GEF Secure no guarda nada todav  — solo te muestra qu  va a pasar:

Estado	Qu� significa
Nuevo	Ese paquete no estaba cargado en este activo, se va a crear.
Actualizado	Ya exist� pero con otra versi�n — se va a actualizar la versi�n.
Sin cambios	Ya existe exactamente igual, no hace falta tocar nada.
No reconocido	Syft no pudo identificar el paquete de forma est�ndar (sin versi�n resuelta, por ejemplo) — no se importa, hay que cargarlo a mano si hace falta.
Error	Hubo un conflicto al guardar (ej. ya existe otro componente con el mismo software+versi�n en el mismo entorno) — no se importa.

6. Revis  la tabla. Si est  todo bien, hac  clic en **«Confirmar importaci n»**.
7. Listo — el software queda cargado en el activo, con las coordenadas exactas que usa Syft, listo para escanear desde el Centro de Escaneos como cualquier otro componente.

Qui n puede hacerlo

Solo usuarios con rol **ADMIN** o **SECURITY_ANALYST** ven el bot n «Importar inventario».

L mites

El archivo no puede superar los 15 MB (los SBOM de proyectos grandes con cientos de dependencias suelen pesar unos pocos cientos de KB, as  que en la pr ctica no deber  ser un problema).

5. Preguntas frecuentes

¿Por qué me aparecen tantos «No reconocidos»?

Puede pasar con artefactos internos del propio build (ej. un wrapper de Gradle, un jar «plain» sin dependencias) que no tienen una coordenada de paquete real. No es un error — simplemente no son software que tenga sentido escanear.

¿Puedo volver a importar el mismo archivo después?

Sí. Si nada cambió, todo va a aparecer como «Sin cambios». Si actualizaste versiones (por ejemplo después de un `mvn versions:use-latest-releases` o un `npm update`), volvé a correr Syft y volvé a importar — los paquetes con versión nueva van a aparecer como «Actualizado».

¿La importación borra el software que ya tenía cargado el activo?

No. Solo agrega o actualiza — nunca borra software existente, aunque no aparezca en el nuevo SBOM.